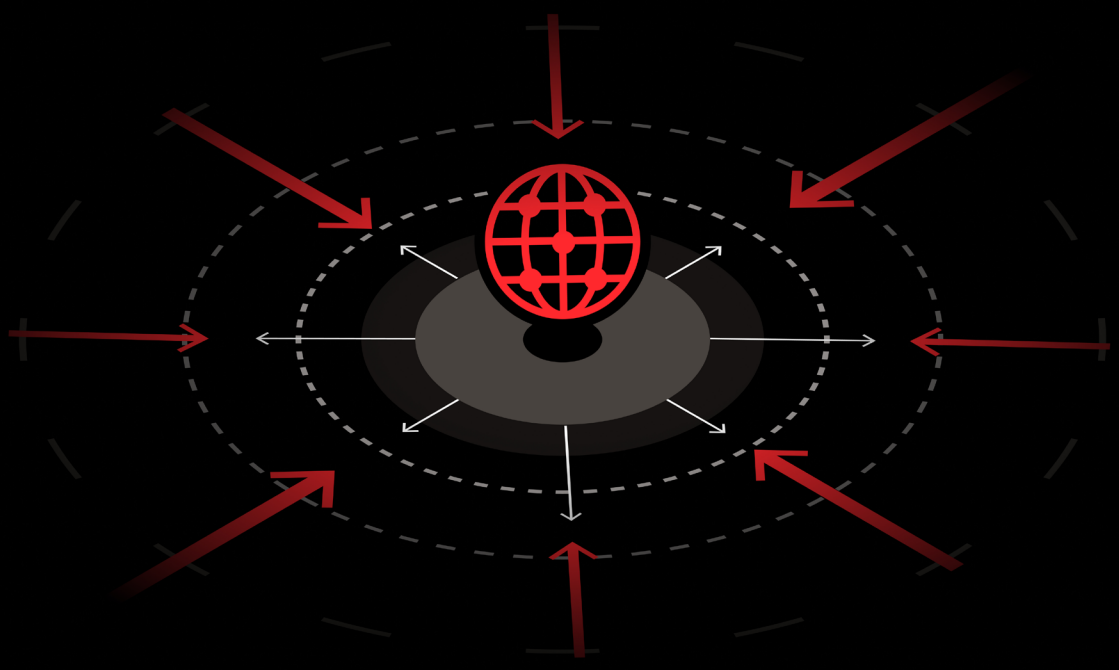
Recherche sur la sécurité mondiale

Le coût de la vitesse IA

Pourquoi les entreprises agiles remédient parfois plus lentement aux failles de sécurité



fastly

Table des matières

01 Résumé

03 Le paradoxe de l'« AI-first »

03 L'IA crée sa propre surface d'attaque
04 L'impact financier des scrapers par IA
04 La WAAP devient essentielle

05 Quand les bugs l'emportent sur les failles

05 Les bugs logiciels ont déclenché

06 Une lueur d'espoir dans la reprise après un incident

06 L'investissement dans les capacités de réponse porte ses fruits

07 Priorités d'investissement : où vont réellement les fonds consacrés à la sécurité

07 Compte tenu de l'augmentation des risques, il n'est pas étonnant que la protection des données et la confidentialité soient en tête des priorités d'investissement avec 37 %

08 Les RSSI ont davantage de responsabilités, mais bénéficient d'un soutien insuffisant

08 Les changements de politique passent à côté de l'essentiel
08 Personne ne sait qui est responsable

09 Remédier au manque de compétences

09 Alternatives au recrutement externe
10 Comment les menaces varient selon le secteur

11 La solution : la sécurité dès la conception dans un monde accéléré par l'IA

11 Le plafond de l'automatisation
11 Deux problèmes, une solution
12 Comment améliorer la sécurité dès le départ

13 À propos de cette étude

Résumé

Les entreprises se dirigent à toute vitesse vers une crise de la cybersécurité qu'elles ont elles-mêmes provoquée en raison de leur adoption massive de l'IA. En adoptant les innovations apportées par l'IA sans réfléchir à la manière de renforcer leur sécurité et sans mettre en place un plan stratégique pour implémenter des solutions globales, les entreprises qui s'empressent de se revendiquer « AI-first » découvrent que des fonctionnalités rutilantes, dépourvues d'une infrastructure de défense, créent plus de problèmes qu'elles n'en résolvent.

Pour comprendre ce que vivent les entreprises dans le monde réel, Fastly s'est associée depuis septembre 2025 à l'agence de recherche Sapio pour mener une enquête auprès de 2 000 décideurs informatiques de 21 régions impliqués dans la cybersécurité. Les résultats révèlent une vérité inconfortable : les entreprises les plus agressives en matière d'adoption de l'IA sont celles qui rencontrent le plus de difficultés face aux incidents de sécurité.

Voici ce qui en est ressorti :

Les entreprises paient une lourde taxe sur l'IA.

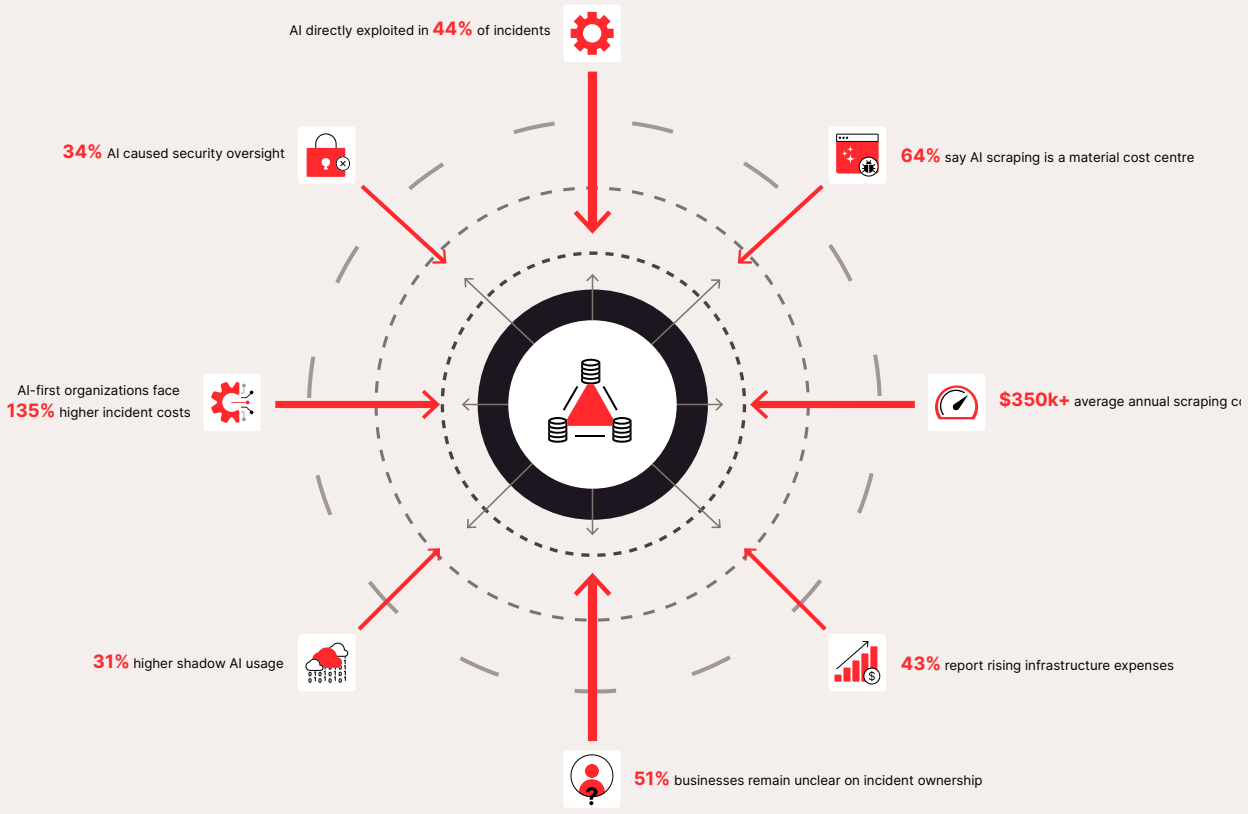
Plus de 75 % des entreprises qui s'identifient comme « AI-first » (ce qui signifie qu'elles ont intégré l'IA dans leurs processus principaux dès le départ, de manière publique ou informelle) mettent en moyenne 80 jours de plus que leurs homologues pour se remettre d'incidents de sécurité. Il faut en moyenne 6,8 mois dans toutes les régions pour que les entreprises « AI-first » se rétablissent, et 3,9 mois pour toutes les autres.

L'impact financier est également plus douloureux pour les entreprises utilisant l'IA : les incidents coûtent aux entreprises « AI-first » 135 % de plus qu'à leurs homologues, consommant 3,13 % de leurs revenus annuels contre 1,33 % pour les entreprises non « AI-first », ce qui représente des milliards de dollars de pertes de revenus. Près de la moitié (44 %) déclarent que l'IA a été directement exploitée lors de leur dernier incident.

suite à la page suivante

L'élargissement de la surface d'attaque :

L'IA se développe plus vite que la sécurité ne peut suivre



L'empreinte de infrastructure s'étend plus vite que les défenses ne peuvent le faire. Le Shadow AI, ou IA fantôme, a également fait un bond au cours des 12 derniers mois. Plus d'un tiers (34 %) des premières entreprises « AI-first » déclarent que l'exploitation directe de l'IA a contribué à leur dernier incident, et 30 % déclarent que l'utilisation de l'IA a conduit à une négligence qui a contribué à l'incident. Entre-temps, le scraping par IA est devenu un centre de coûts matériels pour plus de deux tiers (64 %) des entreprises, les coûts d'infrastructure annuels moyens ayant augmenté de près de 350 000 $. En outre, 43 % des personnes interrogées ont fait état d'une augmentation des dépenses liées à l'infrastructure. Il ne s'agit pas seulement d'un problème financier : 40 % ont également été confrontés à des perturbations opérationnelles et 29 % ont fait état d'une dégradation de l'expérience client.

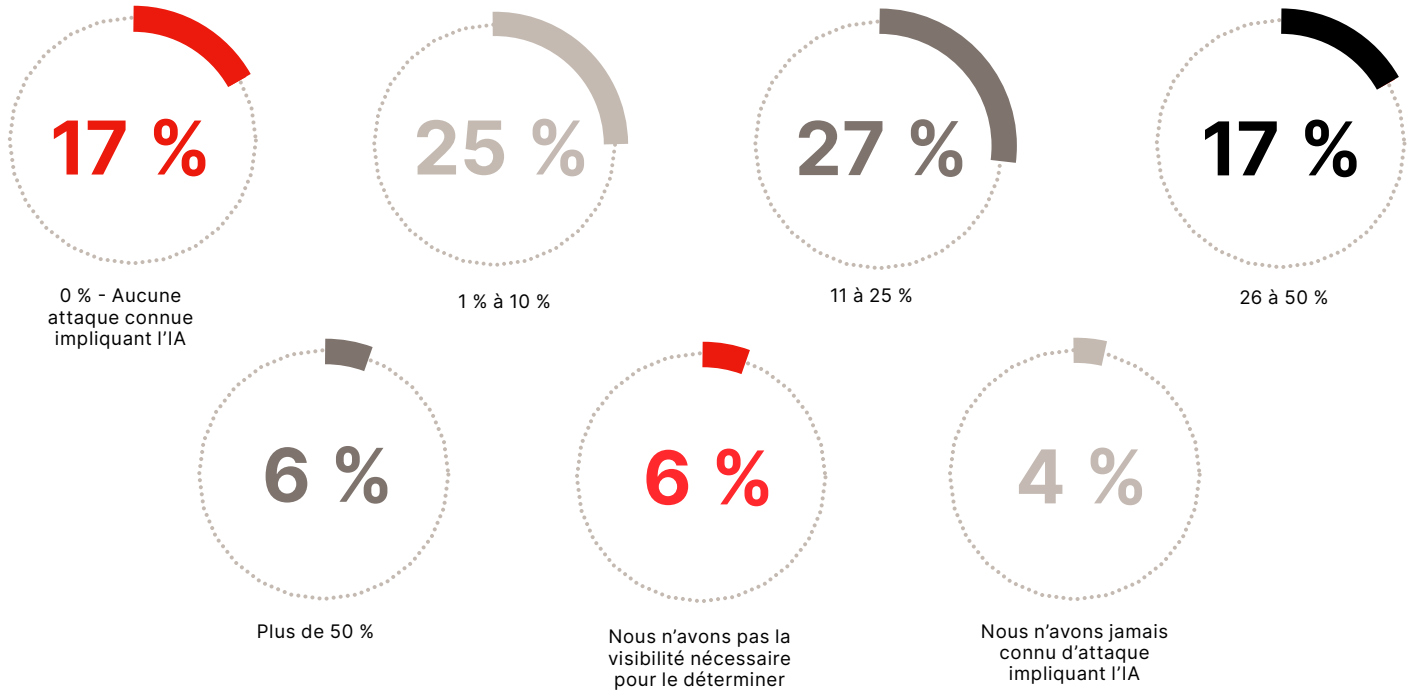
En cas de problème, personne ne sait vraiment qui est responsable. La moitié des entreprises « AI-first » (51 %) avouent ne pas savoir qui gère la réponse aux incidents, contre seulement 23 % pour les autres entreprises. La notion traditionnelle de responsabilité se dégrade rapidement, car les équipes peuvent désormais inclure des humains et des agents d'IA capables de penser, d'apprendre et d'agir de manière autonome.

Il y a un point positif dans les données. Le volume global des incidents pour toutes les entreprises est resté stable avec une moyenne de 41 incidents par entreprises, et les capacités de récupération se sont améliorées. Le temps moyen de récupération a diminué de plus d'un mois, passant de 7,34 mois l'année dernière à 6,08 mois. Les pertes de revenus dues aux incidents sont tombées à 2,68 % des revenus annuels, contre 2,98 % auparavant. Les entreprises qui ont investi dans des analyses post-incident (52 %) et l'automatisation des réponses (43 %) font probablement partie de celles qui constatent des résultats positifs.

Les priorités d'investissement évoluent pour répondre aux risques spécifiques à l'IA. Les outils de découverte d'agents représentent 56 % des dépenses de sécurité consacrées à l'infrastructure d'IA agentique, suivis par la sécurité des API (55 %) et les pare-feux d'application web (54 %). Les trois quarts (75 %) des personnes interrogées s'inquiètent des attaques de déni de service distribué (DDoS) ciblant les agents d'IA, tandis que 53 % reconnaissent manquer d'expertise en sécurité spécifique à l'IA.

Pour améliorer la sécurité, une évolution des mentalités s'impose. Les entreprises doivent surveiller l'activité des bots d'indexation IA, anticiper l'adoption du shadow IA (l'IA fantôme) et renforcer les défenses périmétriques avant d'étendre la surface d'attaque. Il faut également repenser les solutions de protection des applications Web et des API (WAAP) ; les entreprises commencent à les considérer comme une infrastructure essentielle à leur activité plutôt que comme des solutions de niche.

Les entreprises « AI-first » ont tendance à subir des compromis liés à l'IA



Le paradoxe de l'« AI-first »

L'IA est un potentiel stimulant de la productivité, mais comme pour tout levier technologique, elle nécessite un équilibre stratégique entre innovation et sécurité. Les entreprises qui se présentent comme « AI-first » et qui cherchent à intégrer l'intelligence artificielle doivent trouver cet équilibre pour réellement appliquer les avantages de l'IA. À l'heure actuelle, ces entreprises mettent en moyenne 6,8 mois à se remettre d'incidents de cybersécurité, soit 80 jours de plus que leurs homologues non « AI-first » qui se rétablissent en environ 4 mois. Elles ont du pain sur la planche.

> « Les outils d'IA eux-mêmes vont devenir des parties privilégiées de votre infrastructure, et c'est précisément là que réside le risque. »
>
> **Marshall Erwin, CISO chez Fastly**

L'innovation est un avantage commercial crucial, mais les entreprises qui mettent en place des mesures de sécurité robustes pour protéger les données, les infrastructures et les processus de l'IA seront mieux placées pour innover que celles qui ne le font pas. Les incidents coûtent aux entreprises « AI-first » 135 % de plus qu'aux entreprises non « AI-first ». Le temps de reprise se traduit directement par des pertes de revenus, des temps d'arrêt prolongés et une atteinte durable à la réputation de l'entreprise.

L'IA crée sa propre surface d'attaque

L'IA introduit plus de complexité, plus de code et plus d'infrastructure que les entreprises doivent protéger. Près de la moitié (44 %) des entreprises « AI-first » déclarent que l'IA a été directement exploitée dans leur dernier incident de sécurité, contre seulement 6 % pour les entreprises non « AI-first ».

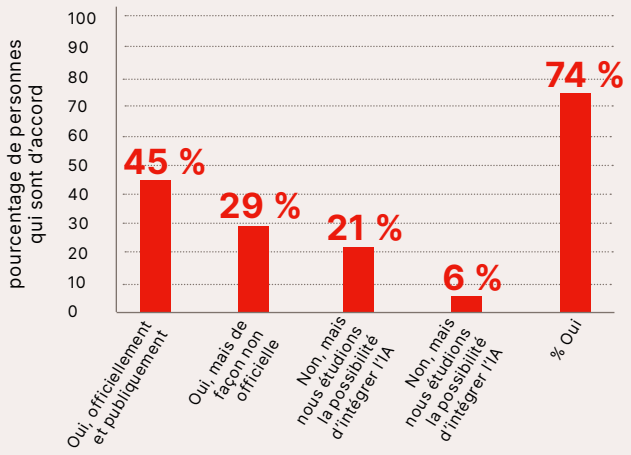
L'une des causes premières tient à ce qui échappe à la vigilance des équipes de sécurité. L'utilisation de l'IA fantôme « shadow AI » (des outils non autorisés que les employés adoptent sans l'approbation du service informatique) est 31 % plus fréquente chez un quart des employés des entreprises « AI-first », probablement parce que la culture encourage l'innovation avec l'IA. Mais pour Marshall Erwin, CISO chez Fastly, les outils d'IA approuvés posent tout autant de problèmes que l'IA fantôme « shadow AI ».

Les outils d'IA approuvés reçoivent souvent des autorisations automatisées étendues, et les entreprises qui luttaient déjà avec la gestion des identités et des accès dans un monde pré-IA voient ce problème exploser. « Ces outils vont étendre les risques d'accès potentiels », prévient Erwin. « Les outils d'IA eux-mêmes vont devenir des parties privilégiées de votre infrastructure, et c'est précisément là que réside le risque. »

Les chiffres confirment cette conclusion. Plus d'un tiers (34 %) des entreprises « AI-first » citent l'utilisation de l'IA comme un facteur dans les lacunes de sécurité qui ont contribué à leur dernière faille de sécurité. Ce chiffre est à comparer aux 20 % observés dans les entreprises traditionnelles.

Considérez les outils d'IA comme des entités machine nécessitant leur propre gouvernance des identités. Les privilèges automatisés permettent des attaques automatisées. Plus ces outils deviendront agentiques (c'est-à-dire plus leurs tâches autonomes seront complexes), plus ce risque augmentera.

Les entreprises « AI-first » ont mis plus de temps à se remettre des incidents de sécurité que celles qui ne sont pas « AI-first »



1 (utilisation par les employés d'outils d'IA non autorisés)

L'impact financier des scrapers par IA

IA Shadow (L'IA fantôme) favorise les utilisations abusives et accidentelles de l'IA au sein d'une entreprises, mais il existe également des risques liés à l'utilisation de l'IA par des tiers. Ces acteurs malveillants peuvent cibler le contenu d'une entreprises en utilisant des bots de scraping. Le scraping par IA coûte cher aux entreprises car il met leur infrastructure à rude épreuve.

Environ deux tiers des entreprises (64 %) affirment que le scraping par IA est devenu un centre de coûts important, avec des dépenses dépassant en moyenne 348 000 $ par an. Cela affecte durement les factures d'infrastructure et les budgets opérationnels. Plus de quatre entreprises sur dix ont vu les dépenses d'infrastructure augmenter à mesure que l'activité liée à l'IA s'intensifiait. Par ailleurs, 40 % font état de perturbations opérationnelles, tandis que 29 % sont confrontées à des problèmes d'expérience utilisateur. Des temps de chargement trop longs, des fonctionnalités défaillantes et des performances dégradées sont le genre de problèmes qui, s'ils persistent, poussent les clients à aller voir ailleurs.

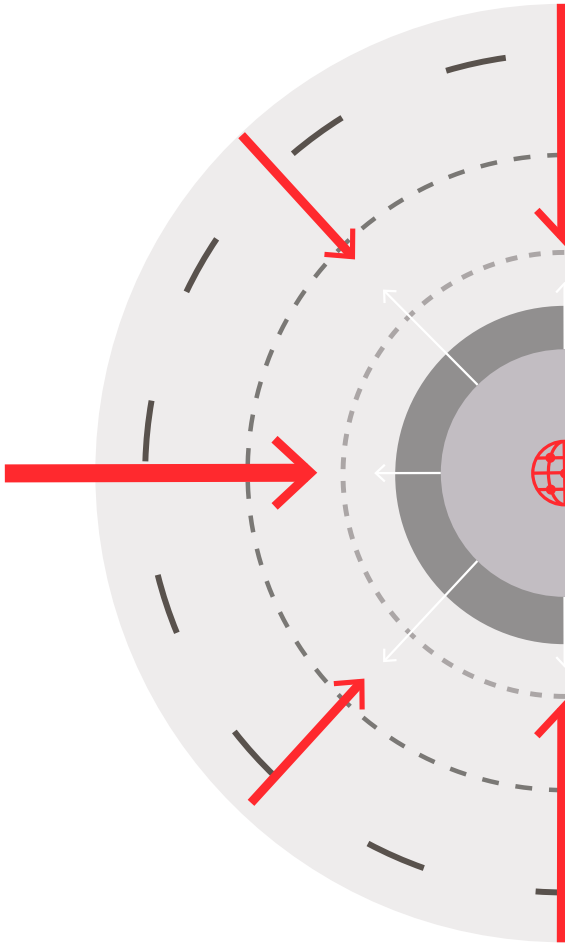
Les techniques d'attaque externe traditionnelles peuvent causer de graves dommages à l'infrastructure de l'IA. Trois quarts des répondants à l'enquête de Fastly s'inquiètent des attaques par déni de service distribué (DDoS) qui touchent les agents d'IA. Cela signifie que même les entreprises qui n'utilisent pas l'IA en interne doivent être attentives à la manière dont d'autres pourraient l'utiliser pour les exploiter.

Aucun de ces risques ne devrait empêcher les entreprises d'adopter l'IA, mais les gagnants seront ceux qui innovent tout en adaptant leurs mesures de sécurité en conséquence. Cela signifie soit trouver les compétences nécessaires (53 % admettent que leurs équipes de sécurité ne possèdent pas l'expertise spécifique en IA pour gérer ces menaces), soit travailler avec un partenaire tiers pour aider à gérer les risques.

La WAAP devient essentielle

Ces réalités modifient la façon dont les entreprises conçoivent leurs architectures de sécurité. La protection des applications Web et des API (WAAP) figurait peut-être autrefois en bas de la liste des outils de sécurité pour certaines entreprises, mais elle est désormais en train de devenir un élément essentiel de leur infrastructure. Il s'agit de la couche de contrôle permettant de gérer les coûts et de sécuriser les API qui sous-tendent les services numériques modernes, tant à l'intérieur qu'à l'extérieur de l'entreprise.

Les entreprises votent avec leur portefeuille. Lorsqu'elles investissent dans la protection de l'infrastructure agentique, les entreprises accordent la priorité à la détectabilité agentique (56 %), à la sécurité des API (55 %) et aux firewallx d'applications web (WAF, à 54 %). Ces catégories de sécurité non traditionnelles sont des réponses directes à des modèles architecturaux qui existaient à peine il y a deux ans.



Quand les bugs l'emportent sur les failles

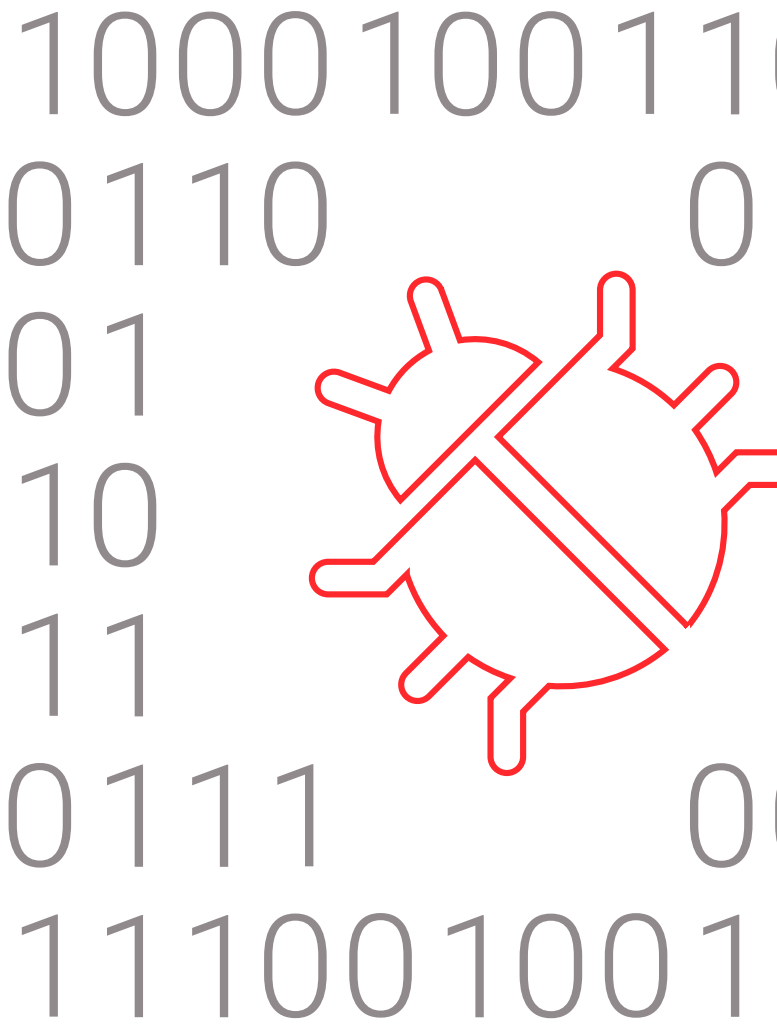
Notre étude a montré qu'en 2025, le nombre d'incidents de sécurité est resté stable. Les entreprises ont fait face à une moyenne de 41 incidents connus, soit seulement un de plus qu'en 2024. Mais ce chiffre global ne veut quasiment rien dire. C'est la nature même des failles qui livre un constat bien plus réaliste.

Les bugs logiciels ont déclenché 40 % des incidents, contre 33 % en 2024, ce qui les a fait passer de la deuxième à la première place, reléguant la cause principale précédente (hackers externes) à la deuxième place avec 39 %.
Les erreurs de configuration ont pris la troisième place, passant de 25 % l'année dernière à 29 %. Plus que jamais, les entreprises sont confrontées à des défaillances de sécurité qui n'ont rien à voir avec des acteurs malveillants, mais tout à voir avec la manière dont elles écrivent leur code ou configurent leur infrastructure (ce qui se fait de plus en plus souvent avec du code).

Les bugs logiciels ont en réalité déclenché 40 % des incidents, contre 33 % en 2024.

Quatre-vingt-dix pour cent des entreprises ont subi au moins un incident de cybersécurité, mais il est clair que ces incidents découlent de problèmes de développement, de problèmes de processus et peut-être de problèmes culturels au sein de l'entreprise. S'il est clair que les entreprises ne peuvent pas relâcher leur vigilance sur leur périmètre, il est temps pour elles de porter leur attention sur l'allocation budgétaire et la structure de leurs équipes, plutôt que de s'organiser exclusivement autour des menaces externes.

L'échelle amplifie tous ces problèmes. Les grandes entreprises de plus de 10 000 employés ont enregistré en moyenne 57 incidents, soit près de 40 % de plus que la moyenne de 40. Les surfaces d'attaque étendues et les pipelines de développement enchevêtrés augmentent les risques de défaillance. Les petites entreprises rencontrent les mêmes problèmes à une échelle plus réduite, ce qui aide mais ne résout pas complètement le problème.



Une lueur d'espoir dans la reprise après incident

L'enquête Fastly a révélé une véritable bonne nouvelle : les entreprises se remettent de plus en plus vite des cyberattaques. Le délai moyen de récupération est passé à 6,08 mois en 2025 contre 7,34 mois l'année précédente. Cela représente plus d'un mois de réduction sur le calendrier de récupération, ce qui constitue une amélioration significative lorsque chaque jour de temps d'arrêt coûte de l'argent et érode la confiance des clients.

L'écart entre les attentes et la réalité se réduit également. Les entreprises prévoient désormais un délai de récupération de 5,89 mois, et le délai réel de 6,08 mois est remarquablement proche. Cet alignement suggère que les entreprises élaborent des plans de réponse aux incidents plus réalistes, fondés sur l'expérience réelle plutôt que sur des vœux pieux.

Les impacts financiers évoluent également dans la bonne direction. Les pertes de revenus ont en moyenne représenté 2,68 % du revenu annuel, en baisse par rapport à 2,98 % l'an dernier. Bien que cela soit toujours douloureux (une entreprise de taille moyenne perdant près de 3 % de ses revenus subit un coup dur), la trajectoire est importante. Les entreprises maîtrisent les dégâts de manière plus efficace qu'il y a douze mois.

Enfin, les clients semblent être plus indulgents une fois qu'ils voient une entreprise faire des efforts pour résoudre ses problèmes de cybersécurité. Il faut en moyenne 4,73 mois pour restaurer l'image de marque, contre 6,08 mois pour une remise en état totale de l'infrastructure et des opérations. Gérer la crise et maintenir la communication avec les clients peut rétablir la confiance même si les équipes techniques sont encore en trin de nettoyer le désordre.

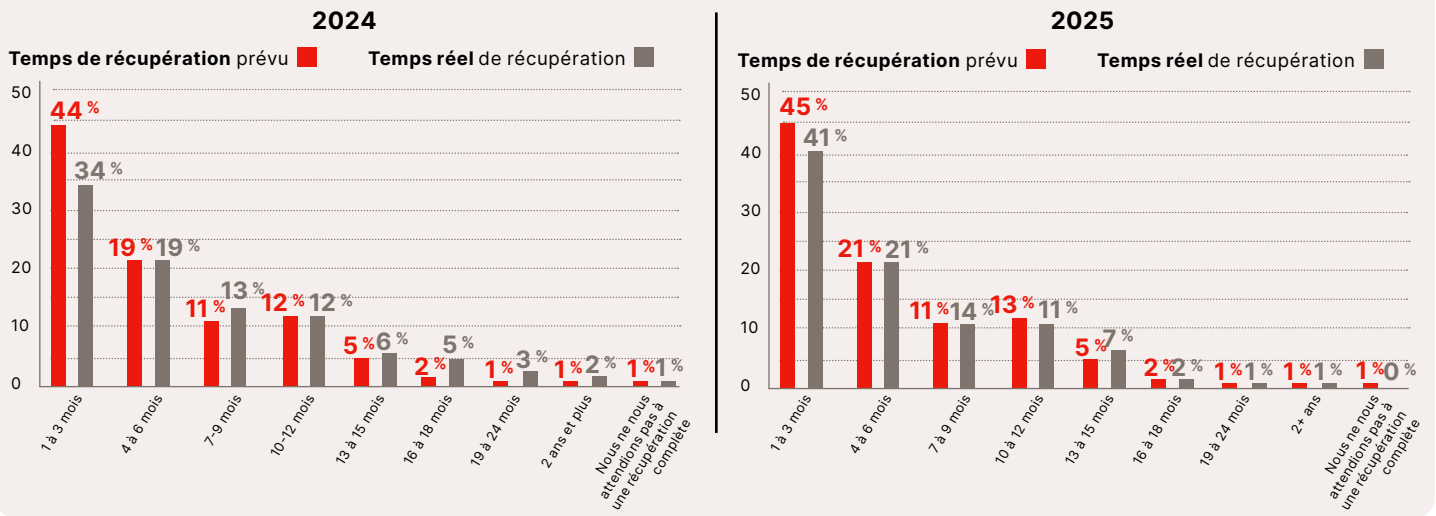
L'investissement dans les capacités de réponse porte ses fruits

Les entreprises investissent de l'argent là où cela compte. Plus de la moitié (52 %) ont investi dans des analyses post-incident, en analysant systématiquement ce qui n'a pas fonctionné et comment l'éviter la prochaine fois. 43 % ont mis en œuvre une automatisation de la réponse, en utilisant la technologie pour accélérer les étapes de confinement et de récupération qui nécessitaient auparavant une intervention manuelle.

Toutefois, ces tendances positives sont à tempérer par des mises en garde importantes. Malgré ces améliorations, 30 % des entreprises ne disposent toujours pas de manuels de réponse aux incidents régulièrement testés. La pression est forte pour réduire encore les délais de récupération.

Et même si les entreprises arrivent à se redresser rapidement, la foudre frappe souvent deux fois, voire plus. Deux tiers (66 %) des entreprises ont subi des incidents répétés dans les trois mois, car des problèmes sous-jacents pourraient encore exister.

Les attentes en matière de restauration deviennent plus réalistes



Priorités d'investissement : où vont réellement les fonds alloués à la sécurité

Demandez aux équipes de sécurité ce qui les inquiète le plus et les failles de données arrivent naturellement en tête de liste avec 45 %. L'ingénierie sociale arrive en deuxième position avec 40 %. C'est logique, étant donné que les e-mails de phishing restent le point de départ de la plupart des attaques réussies. Même la technologie la plus sophistiquée n'empêchera pas un employé pressé de cliquer sur un lien convaincant tard un vendredi après-midi.

Le ransomware (souvent lancé grâce à ces attaques de social engineering) est très en bonne place avec 28 %, après l'IA générative et un manque de compétences techniques. Après des années de gros titres, ce qui ne devrait surprendre personne, les entreprises continuent de tomber dans le panneau. Ce n'est pas parce que les règles du jeu sont désormais bien comprises qu'il est plus facile d'y mettre fin.

Ces risques n'existent pas isolément. Le piratage de compte (19 % des personnes interrogées citent ce problème comme une source d'inquiétude) commence généralement par du phishing.

Cependant, les risques liés aux tiers méritent une attention particulière. L'attaque de septembre contre le dépôt logiciel npm a montré qu'une seule offensive peut infecter des centaines de paquets, distillant ainsi des malwares dans d'innombrables environnements utilisateurs. Lorsque votre sécurité dépend en partie de celle de quelqu'un d'autre, vous vous exposez à des risques que vous ne pouvez pas contrôler directement.

Compte tenu de l'augmentation des risques, il n'est pas étonnant que la protection des données et la confidentialité soient en tête des priorités d'investissement avec 37 %. Le virage vers la protection des données reflète une pression réglementaire croissante et la prise de conscience que les failles de données ont des conséquences dépassant une remédiation technique immédiate. Les violations de conformité, les procès des clients et les dommages à la marque résultent tous d'une mauvaise gestion des données.

La cyberassurance est la deuxième catégorie d'investissement la plus populaire avec 34 %, suivie par la sécurité des API avec 33 %. La deuxième place de la cyberassurance est un signe d'acceptation. Les entreprises se rendent compte qu'une défense parfaite est impossible et transfèrent donc les risques. Vous ne pouvez pas empêcher toutes les failles ? Assurez-vous au moins de ne pas en encaisser seul le choc financier lorsqu'un incident se produit.

Compte tenu de l'augmentation des risques, il n'est pas étonnant que la protection des données et la confidentialité soient en tête des priorités d'investissement avec 37 %.

Les investissements dans la sécurité des API sont judicieux lorsqu'on considère que chaque nouvelle application mobile, intégration tierce et microservice crée un autre point d'entrée potentiel. Les API étaient autrefois de la tuyauterie interne. Maintenant, elles sont exposées à Internet et les hackers l'ont remarqué.

Le véritable basculement des investissements se manifeste dans l'IA. L'enquête a révélé que les entreprises se préparent à faire face aux menaces pesant sur les infrastructures agentiques. Parmi ceux qui investissent dans ce domaine, la détectabilité agentique arrive en tête de liste avec 56 %, suivie par la sécurité des API à 55 % et les WAF à 54 %. Ces catégories de sécurité non traditionnelles sont des réponses à des modèles architecturaux qui existaient à peine il y a deux ans.

Les trois quarts des entreprises s'inquiètent des attaques de déni de service distribué ciblant les agents d'IA, et plus de la moitié admettent que leurs équipes ne possèdent pas l'expertise spécifique en IA nécessaire pour gérer ces menaces. Pourtant, la protection DDoS se classe au cinquième rang des priorités d'investissement, avec 30 %. Il y a un décalage entre les préoccupations déclarées et les dépenses réelles, ce qui suggère soit des priorités mal placées, soit des budgets restreints qui obligent à faire des compromis inconfortables.

---

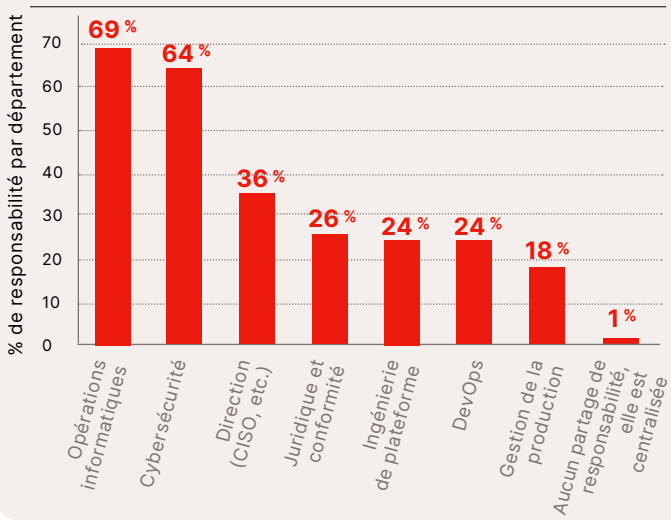
2 « Widespread Supply Chain Compromise Impacting Npm Ecosystem | CISA. » Cybersecurity and Infrastructure Security Agency CISA, 23 septembre 2025, www.cisa.gov/news-events/alerts/2025/09/23/widespread-supply-chain-compromise-impacting-npm-ecosystem

Les RSSI ont davantage de responsabilités, mais bénéficient d'un soutien insuffisant

La pression qui pèse sur les épaules des RSSI s'intensifie. Près de trois quarts (73 %) des entreprises estiment désormais que la responsabilité ultime en cas d'intrusion repose entièrement sur eux. La pression réglementaire montre de plus en plus que les leaders de la sécurité peuvent être tenus personnellement responsables des failles. Par exemple, la directive européenne NIS2 de 2022 autorise la suspension temporaire des cadres jugés incapables d'assumer leurs responsabilités en matière de cybersécurité, ainsi que l'imposition de dommages-intérêts aux directeurs et aux PDG.

L'implication des RSSI dans la réponse aux incidents a également augmenté, 82 % des répondants déclarant une participation active et 74 % ayant constaté un engagement accru des CISO au cours de l'année écoulée. Sur le papier, il semble que la sécurité reçoive l'attention qu'elle mérite de la part de la direction. Dans la pratique, la réponse a été moins impressionnante.

En matière de cybersécurité, chacun a un rôle à jouer



Les changements de politique passent à côté de l'essentiel

La plupart des entreprises (94 %) ont modifié leurs politiques en réponse à la responsabilité croissante des CISO. Mais si l'on se penche sur ce que ces changements impliquent réellement, la situation se complique. De nombreuses mesures sont défensives, 42 % promettant une surveillance accrue de la documentation relative à la sécurité (en d'autres termes, une bonne lecture des règles). Parmi les répondants, 45 % offrent désormais plus de soutien juridique au personnel chargé de la cybersécurité.

Ce sont ce que l'on appelle familièrement des politiques « parapluie », destinées avant tout à couvrir ses arrières. « Ces mesures sont bonnes, mais ne vont pas au-delà d'un instinct de conservation », commente Marshall Erwin, CISO de Fastly. « Elles n'améliorent en rien leur posture de sécurité. »

L'une des mesures les plus courantes, citée par 44 %, consiste à enfin accorder au RSSI une place à la table des décisions stratégiques (ce qui est presque à égalité avec le soutien juridique supplémentaire et les ressources pour les équipes de cybersécurité, qui arrivent chacune à 45 %). Cela leur donne au moins une sorte de voix, mais ce n'est pas assez pour enrayer le mal. Les leaders de la sécurité doivent avoir l'autorité et les ressources nécessaires pour mettre en œuvre les mesures de sécurité nécessaires, et pas seulement la responsabilité lorsque les choses tournent mal.

Personne ne sait qui est responsable

La confusion ne se limite pas aux vulnérabilités techniques, mais s'étend à la structure organisationnelle. Plus de la moitié des entreprises « AI-first » signalent un manque de clarté quant à la responsabilité de la réponse aux incidents, contre seulement 23 % pour les entreprises non « AI-first ». Pourtant, lorsque des failles se produisent, la responsabilité remonte, avec 79 % des entreprises « AI-first » signalant que le CISO est tenu pour responsable contre 57 % parmi les organisations traditionnelles.

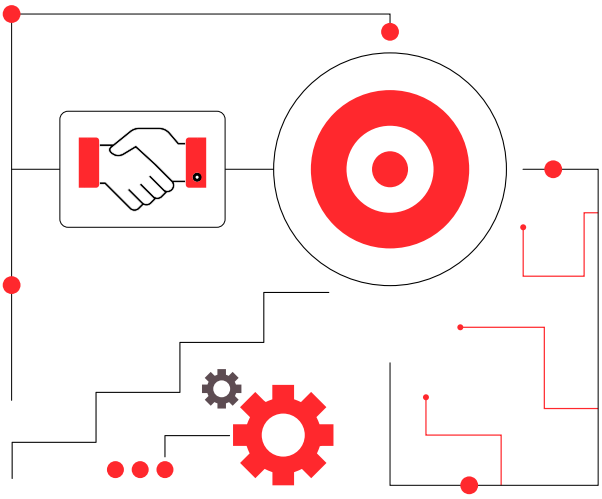
Alors que les entreprises « AI-first » créent de nouveaux risques plus rapidement qu'elles ne peuvent les gérer, cette question va devenir la priorité absolue des responsables de la sécurité. C'est à eux qu'incombera la responsabilité des failles inévitables qui résulteront de ces risques.

La confusion ne pose pas que des problèmes au sommet. Notre étude montre que 43 % des personnes interrogées au sein de l'entreprise estiment que les responsabilités en cas d'incident sont claires, tandis que le même pourcentage estime qu'elles ne le sont pas (le reste des personnes interrogées étant indécises).

3 PricewaterhouseCoopers. « What You Need to Know about NIS2 - PwC. » PwC, 2023, www.pwc.de/en/cyber-security/european-nis2-directive-implications-for-businesses-and-institutions.html.

Remédier au manque de compétences

Le problème des talents s'aggrave au lieu de s'améliorer. Plus de la moitié (53 %) des équipes de sécurité ne disposent pas de l'expertise spécifique en IA nécessaire pour répondre aux menaces émergentes. Il ne s'agit plus seulement de compétences générales en matière de cybersécurité. L'adoption rapide des infrastructures d'IA a créé une demande de connaissances spécialisées que le marché ne peut pas satisfaire.



Les entreprises « AI-first » sont particulièrement avides de talents. Elles évoluent rapidement et construisent de nouveaux systèmes. Elles découvrent également que l'expertise en sécurité traditionnelle ne s'applique pas facilement à la protection des agents d'IA, à la gestion des infrastructures agentiques ou à la défense contre les attaques alimentées par l'IA. La pénurie de compétences est devenue un goulot d'étranglement qui limite la vitesse à laquelle elles peuvent sécuriser leurs empreintes technologiques en expansion.

Les jeunes diplômés en cybersécurité font face à une longue période d'apprentissage. Ils doivent acquérir des compétences techniques spécifiques à l'ensemble d'outils et aux flux de travail de l'entreprise, ainsi que des connaissances sur les nuances culturelles propres à l'entreprise. Il faut beaucoup de temps et d'efforts avant qu'une nouvelle recrue ne devienne productive. À mesure que les entreprises grandissent, ce défi s'intensifie, en particulier lorsqu'il s'agit de travailler dans des environnements plus vastes et en constante évolution.

Alternatives au recrutement externe

Peut-être que les entreprises devraient plutôt se tourner vers l'intérieur. Plusieurs options méritent d'être envisagées. Former vos employés actuels à de nouvelles responsabilités vous permettra de vous assurer qu'ils comprennent vos systèmes et processus (au moins en partie), en agissant dans le respect de votre culture d'entreprise. Ces personnes comprennent le contexte métier, qui compte autant que la capacité technique lorsqu'on prend des décisions de sécurité sous pression.

Le mentoring permet de fournir une formation sur site dispensée par du personnel expérimenté afin de renforcer les compétences des nouveaux employés et de leur donner les moyens de réussir. C'est moins rapide que d'embaucher quelqu'un qui a 10 ans d'expérience, mais ces candidats expérimentés sont de plus en plus difficiles à trouver et leur recrutement coûte de plus en plus cher.

La communication entre le service de sécurité et les autres équipes, notamment l'informatique, la conformité, l'assistance et le développement produit, permet aux employés d'être plus polyvalents, en étant plus conscients de la manière dont la sécurité s'intègre à leurs rôles. Il est possible d'envisager d'affecter certaines personnes à cette tâche.

Recruter les talents en interne, particulièrement ceux provenant d'autres services, peut apporter plusieurs avantages. Cela soutient l'idée que la sécurité relève de la responsabilité de tous les employés. Cela soutient également les efforts de transformation numérique en intégrant l'expertise en sécurité dans toute l'entreprise plutôt que de la concentrer dans une seule équipe qui devient un goulot d'étranglement.

Comment les menaces varient selon le secteur

Les données globales sont révélatrices, mais si l'on examine les différents secteurs, on s'aperçoit que la charge de la cybersécurité est très inégale d'une industrie à l'autre. Certaines entreprises voient la viabilité même de leur modèle d'affaires remise en cause, tandis que d'autres sont confrontées à des risques géopolitiques ou au chaos opérationnel lié à la sécurisation de parcs numériques tentaculaires. Voici comment le paysage des menaces se compose secteur par secteur.

Finance

Le secteur financier enregistre en moyenne 54 failles par an. Le phishing inquiète toujours **39 %** des entreprises, et les failles de données **42 %,** mais le chiffre le plus alarmant est le montant de **442 232 $**. Il s'agit du surcoût annuel moyen des infrastructures lié au seul scraping par l'IA, un montant record tous secteurs confondus. C'est peut-être la raison pour laquelle l'IA générative inquiète **41 %** des institutions financières. Seules les entreprises technologiques sont plus inquiètes à ce sujet.

Médias et divertissement

Ce secteur n'est pas du tout comme les autres. Il compte le plus petit nombre de failles de tous les secteurs, soit 24. Toutefois, le scraping de contenu constitue une menace pour le modèle d'entreprise : une entreprise sur cinq considère qu'il s'agit d'une préoccupation majeure, contre **5 à 16 %** dans les autres secteurs. Cela se reflète dans les **51 %** des entreprises de médias qui subissent des coûts d'infrastructure élevés à cause de l'IA scraping, les **47 %** qui rencontrent des perturbations opérationnelles et les **39 %** qui signalent des problèmes d'expérience client. Tous ces chiffres sont des records intersectoriels. Seuls **11 %** ne signalent aucun impact.

Gouvernement

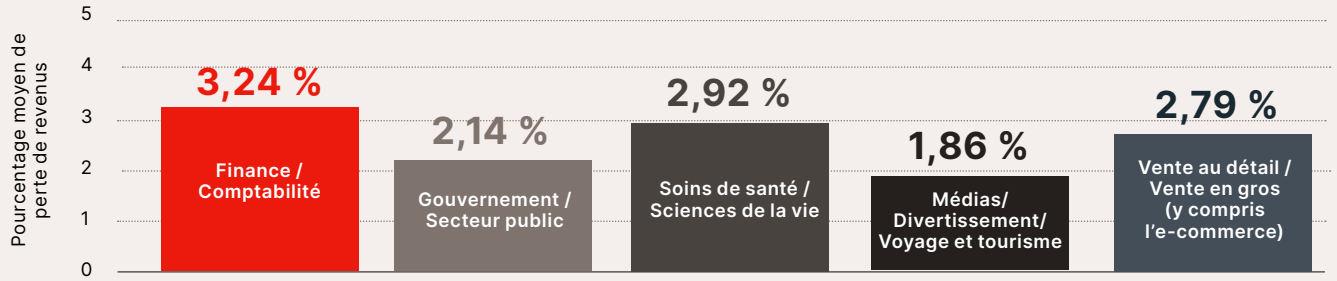
Les attaques d'États-nations constituent, sans surprise, la préoccupation majeure des répondants du secteur public, inquiétant **21 %** des équipes de sécurité (nettement plus que dans le secteur privé). Le pourcentage s'inquiétant des failles de données atteint **52 %**, le taux le plus élevé tous secteurs confondus.

Vente au détail

Le secteur de la distribution semble être attaqué de toutes parts. Les attaques par déni de service distribué (DDoS) sont une préoccupation pour **25 %** des répondants de ce secteur (le taux le plus élevé tous secteurs confondus), tandis que leurs inquiétudes face aux ransomwares rejoignent celles du secteur financier, à hauteur de **32 %**. De plus, la pénurie de compétences record de **32 %** signifie que les systèmes de paiement et les données des clients ne sont pas correctement protégés.

Les secteurs peuvent présenter des différences qui les amènent à se classer différemment dans divers aspects de la cybersécurité, mais une chose est universelle : ils paient désormais tous une taxe sur l'IA. Les coûts de scraping varient de près de **300 000 $ à 450 000 $** par an dans les secteurs nommés. Les menaces traditionnelles telles que les attaques d'identité et les données erronées n'ont pas disparu, mais l'IA a ajouté de nouveaux coûts obligatoires à la gestion des opérations numériques.

Les entreprises financières sont celles qui ont le plus perdu en moyenne à la suite de leur plus gros incident de sécurité en 2025



La solution : la sécurité dès la conception dans un monde accéléré par l'IA

Les erreurs internes étant désormais à l'origine d'autant de failles que d'attaques externes et les bugs logiciels déclenchant 40 % des incidents, on pourrait s'attendre à ce que cela ait provoqué une remise en question fondamentale de la manière dont les organisations conçoivent leurs logiciels. Mais cela n'a pas été le cas.

> « Je ne peux pas attendre que quelqu'un vienne me demander une approbation, car si cela se produit, j'ai probablement déjà échoué. »
>
> **Marshall Erwin, CISO chez Fastly**

Seulement 37 % ont transféré la responsabilité de la sécurité aux équipes d'ingénierie de plateforme ou DevOps.

Il est essentiel de participer aux conversations avant de prendre des décisions en matière d'architecture. « Je ne peux pas me permettre d'attendre que l'on vienne me demander mon approbation ; si cela arrive, c'est sans doute que j'ai déjà échoué dans ma mission », explique Marshall Erwin.

L'automatisation DevOps est utile, mais uniquement en cas de problèmes tactiques. Votre pipeline d'intégration continue/de distribution continue (CI/CD) ne détectera pas les erreurs architecturales telles que l'octroi de privilèges excessifs à un agent d'IA, ce qui expose votre infrastructure aux attaques. Il faut faire appel au jugement humain lors de la conception.

Le plafond de l'automatisation

L'automatisation est un élément important de l'équation de la sécurité, car elle permet de combler le manque de talents. Cependant, même les entreprises engagées dans l'automatisation atteignent des limites. « Le volume de vulnérabilités potentielles que vous devez examiner et anticiper est élevé pour à peu près toutes les entreprises matures du secteur technologique actuel », note Marshall Erwin. Combinez un volume élevé à des taux de faux positifs élevés et l'automatisation ne vous mènera pas loin.

Marshall Erwin conseille l'automatisation pour la gestion des problèmes moins graves et le maintien d'experts pour les incidents graves. Laissez les machines gérer les vulnérabilités routinières. Préservez l'expertise humaine pour les tâches délicates qui nécessitent du contexte et du jugement.

Deux problèmes, une solution

L'IA crée des défis de sécurité tant externes qu'internes. D'un côté se pose le problème des coûts opérationnels liés aux menaces externes en rapport avec l'IA. Le scraping par IA épuise tellement les budgets d'infrastructure que 64 % des entreprises le considèrent désormais comme un centre de coûts important. En effet, des bots parcourent leurs sites, consomment de la bande passante, réduisent les performances et augmentent leurs factures d'hébergement (sans parler de l'appropriation illicite de leur précieuse propriété intellectuelle).

De l'autre côté se trouve le problème de surface d'attaque auquel est confrontée l'infrastructure d'IA des entreprises. L'infrastructure agentique et les outils d'IA disposant de privilèges d'accès créent de nouveaux vecteurs pour les attaquants. Ces outils disposant de privilèges élevés peuvent, s'ils sont exploités, permettre aux hackers d'accéder en profondeur à l'infrastructure.

Les deux problèmes convergent au même point : les applications web et les API. Les solutions WAAP défendent ces deux fronts. La même couche qui empêche les scrapers d'épuiser votre budget d'infrastructure protège également les API qui sous-tendent les systèmes agentiques. Les firewalls pour applications web qui bloquent les attaques de la septième couche sont efficaces, que la cible soit une infrastructure traditionnelle ou des agents d'intelligence artificielle. Les entreprises qui investissent dans la sécurité agentique l'ont bien compris.

> « Le volume de vulnérabilités potentielles que vous devez examiner et anticiper est élevé pour presque toutes les entreprises matures dans le secteur technologique aujourd'hui. »
>
> **— Marshall Irwin, CISO chez Fastly**

Comment améliorer la sécurité dès le départ

Les entreprises « AI-first » doivent comprendre l'importance d'une progression mesurée. En allant trop vite au mépris de la sécurité, le temps nécessaire pour réparer les dégâts sera bien plus long. C'est pourquoi les entreprises utilisant l'IA augmentent leurs dépenses de sécurité, mais se sentent pourtant plus vulnérables.

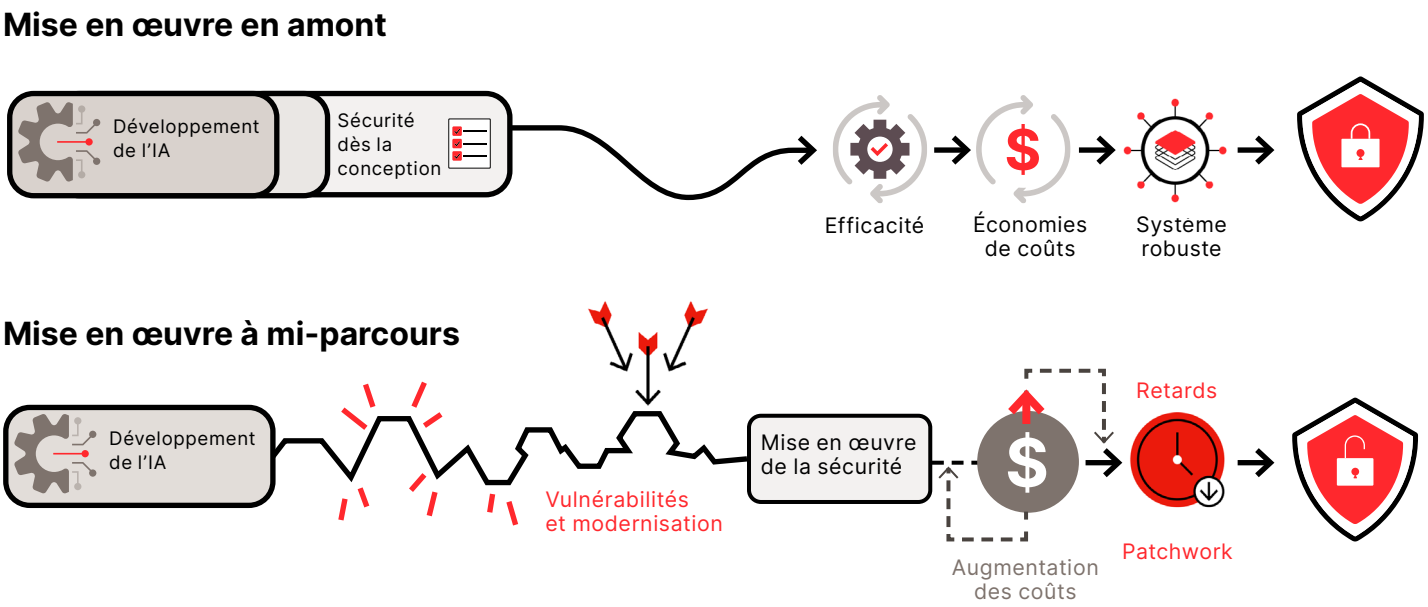
C'est aussi pourquoi la notion de sécurité dès la conception est passée d'un objectif ambitieux à une exigence de survie. Les 81 % qui déclarent que les investissements dans la résilience ont accéléré en toute sécurité leur innovation l'ont déjà compris.

Une architecture de sécurité intégrée aux systèmes dès leur conception élimine l'incertitude, permettant aux équipes d'avancer plus rapidement et en toute confiance. L'alternative est ce que nous voyons aujourd'hui : des entreprises qui dépensent plus, qui se rétablissent plus lentement et qui se demandent pourquoi l'achat d'outils supplémentaires n'a rien réglé. Ce n'est pas une coïncidence si 72 % des entreprises privilégient la rapidité de mise sur le marché plutôt que le renforcement de la résilience des systèmes.

L'IA est en train de réécrire les opérations commerciales à un rythme tel que la migration de l'économie vers le cloud, qui dure depuis dix ans, semble lente en comparaison. Les entreprises qui construisent cette nouvelle infrastructure sans impliquer d'architectes de sécurité dès les premières discussions vont rejoindre la vaste communauté des entreprises « AI-first » qui ont vu l'IA directement exploitée lors de leur dernière faille.

Il y aura une ligne de démarcation entre ceux qui ont intégré la sécurité dans leur stratégie d'IA et ceux qui l'ont ajoutée par la suite. La bonne nouvelle, c'est que vous avez le pouvoir de choisir votre côté.

Les avantages pour la sécurité d'une mise en œuvre de l'IA dès la conception



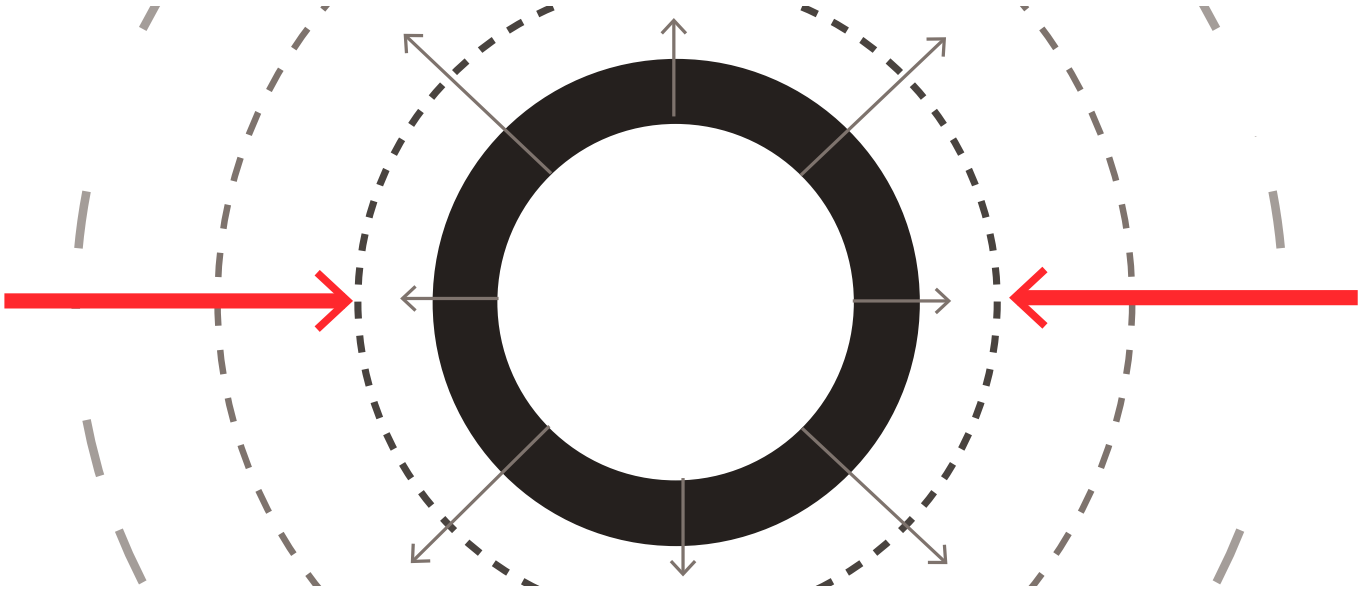
À propos de cette étude

Dans le cadre de cette étude, 2 000 décisionnaires informatiques majeurs ayant une influence sur la cybersécurité ont été interrogés, dans de grandes entreprises couvrant plusieurs secteurs en Amérique du Nord, centrale et du Sud, en Europe, en Asie-Pacifique et au Japon. Les entretiens ont été menés en ligne par Sapio Research au quatrième trimestre 2025, au moyen d'une invitation par e-mail et d'un questionnaire en ligne. Les résultats de chaque échantillon sont sujets à des variations dues à l'échantillonnage.

L'amplitude de toute variation peut être mesurée, étant affectée par le nombre d'entretiens et le niveau de pourcentages indiquant des résultats. Dans le cadre de cette étude particulière, il est probable à 95 % que les résultats de l'étude ne varient pas, majorés ou réduits, de plus de 2,6 points de pourcentage par rapport au résultat qui serait obtenu si les entretiens étaient réalisés auprès de toutes les personnes comprises dans l'univers de l'échantillon.

À propos de Sapio

Finaliste de la meilleure nouvelle agence, Sapio se spécialise dans le sondage d'opinion (avec un accès à plus de 80 millions de personnes dans le monde entier), les groupes de discussion, les entretiens en face-à-face, les entretiens téléphoniques, les études en ligne, les recherches documentaires et la modélisation statistique, entre autres techniques. Le conseil et la recherche B2B comptent parmi ses domaines de prédilection. L'entreprise repose sur des principes de partenariat inspirés des entreprises sociales.

À propos de Fastly, Inc.

La puissante et programmable plateforme edge cloud de Fastly aide les plus grandes marques mondiales à offrir des expériences en ligne rapides, sûres et engageantes grâce à des offres d'edge computing, de distribution, de sécurité et d'observabilité qui améliorent les performances des sites, renforcent la sécurité et favorisent l'innovation à l'échelle mondiale. Comparée à d'autres fournisseurs, l'architecture moderne, performante et puissante de Fastly permet aux développeurs de créer des sites web et des applications sécurisés avec un délai de mise sur le marché rapide et des économies de coûts reconnues comme les meilleures du secteur. Des entreprises du monde entier font confiance à Fastly pour les aider à améliorer leur expérience internet, notamment Reddit, Neiman Marcus, Universal Music Group et SeatGeek. En savoir plus sur Fastly sur https://www.fastly.com, et suivez-nous @fastly.